



Advancing Secure DevSecOps Models to Strengthen Cyber Resilience of U.S. Government Cloud and Federal Information Systems

Taiwo Justice Olorunlana^{1*}, Sodiq Ogunmola²

¹5230 S M L King Jr Pkwy, Beaumont, TX 77705, Lamar University

*Corresponding author, taiwojsuticeo@gmail.com

DOI: <https://doi.org/10.63680/ijstate0126001.001>

Abstract

The rapid transition of U.S. federal systems to cloud infrastructures has introduced new opportunities while simultaneously increasing cybersecurity risks. Traditional, episodic security assessments and perimeter-focused defenses are ill-suited to cloud-native architectures and continuous delivery practices. Secure DevSecOps embedding security throughout development, deployment, and operations presents a pragmatic pathway to increase the cyber resilience of government cloud services and federal information systems. This article synthesizes secondary data from federal standards (NIST SP 800-series), federal programs (FedRAMP), oversight reports (GAO), cybersecurity agencies (CISA), and peer-reviewed literature to (1) characterize the current resilience gap, (2) review DevSecOps mechanisms and evidence for their effectiveness in cloud contexts, (3) present a theoretical framework that links systems engineering resilience to DevSecOps practices, and (4) propose policy and technical recommendations for advancing secure DevSecOps adoption across federal agencies. Findings emphasize automation (IaC & policy-as-code), continuous monitoring/authorization, supply-chain controls, workforce development, and organizational culture as core enablers of resilient federal cloud operations.

Keywords: DevSecOps, Secure DevSecOps, Cyber Resilience, Federal Information Systems, Government Cloud, Zero Trust, FedRAMP, NIST, Continuous Authorization, Supply Chain Security

Introduction

Accelerative evolution in digital transformation of the federal government of United States has moved with a faster pace in a decade; it has been crowned by modernization of legacy systems-the improvement of service delivery and the enhancement of operational efficiency. The transformation has been primarily based on using cloud computing as the main backbone for building rapid scaling infrastructures for federal agencies, capturing shared services, and embracing models of data-driven decision-making (NIST, 2021). This transformation radically transforms the federal cybersecurity landscape on risk. Cloud-native architecture relies on rapid and automated changes, third-party software components, and continuous deployment pipelines conditions which traditional security models at boundaries and periodic compliance checks cannot stand against.

The threats include advanced persistent actor threats increasingly derived from ransomware groups and compromises brought about by the supply chain, exploiting vulnerabilities during software development and deployment rather than at the network perimeter (GAO, 2022). For instance, the SolarWinds compromise showed how gaps embedded in trusted software updates could reproduce into multiple federal agencies with commercial defenses and compromise national security (GAO, 2022). Those incidents demonstrated that after-the-fact security controls focused on compliance were inadequate in a changing landscape. At the same time, federal policy and technical guidance have begun to stress more sustainable development and security, continuous monitoring, and Zero Trust in their strategies. Still, putting those strategies in place on a scale has proven hard. Secure DevSecOps—an evolution of DevOps which builds mechanisms for automating development and operationalization workflows using embedded security controls, policies, and validation—means a bright future in bridging that gap (Rajapakse, 2022).

Unlike traditional security models, secure DevSecOps indicates that security is a seamless and continuous shared responsibility across developers, operators and security professionals. This article asserts that developing secure DevSecOps models rather than superficially embracing DevSecOps will strengthen the cyber resilience of U.S. government cloud and federal information systems. Secure DevSecOps will enable agencies to better anticipate cyber risks, withstand active attacks, recover rapidly from incidents, and adapt to evolving threats by integrating federal resilience theory, Zero Trust architecture, and continuous authorization mechanisms and enabling NIST (2021); FedRAMP PMO (2023).

Literature Review

Over the last few years, the study of DevSecOps and its application to federal cloud and information systems has reached a stage of significant growth with increasing urgency for incorporating security into agile development and cloud-native configurations. This existing body of research considers technical and organizational sides of DevSecOps such as workflow automation for security, continuous monitoring, culture change, and the compliance of federal cybersecurity mandates. By synthesizing scholarly articles, industry reports, and governmental frameworks, this review of literature provides a basis for understanding the challenges, best practices, and opportunities associated with the advancement of DevSecOps models. The literature review attempts to specify the status of knowledge on DevSecOps, identify gaps in its implementation exacerbated by U.S. federal agencies, and create the setting for an investigation into DevSecOps working in cloud-native settings.

DevSecOps in Cloud-Native Environments

The existing body of literature, both practitioners' literature and academic presentations, pictures DevSecOps as a technical methodology and an organizational transformation. Systematic reviews point out that, through such acceptance, attempts can be made to identify vulnerabilities early during the software life cycle within a much shorter time for remediation effort costs compared to normal security testing after deployment (Rajapakse 2022; Mohamed 2025). Some of the core technical practices include automated static and dynamic analysis, dependency scanning, infrastructure as a code (IaC), and policy-as-code enforcement. These reinforce security and speed up deployment cycles toward the continuous delivery of reliable and compliant software.

Depending upon the context of cloud-natives, DevSecOps are of utmost importance, as they are dependent on software-defined infrastructure and microservices-software that continuously undergoes configuration changes and one of the major causes of cloud security incidents-configuration miscalculations, hence justifying the embedding of such validation automation within the pipelines (Mohammed 2025). Other cloud-native architecture components-such as ephemerality in workloads, dynamic scaling, and containerized deployments-invite constant monitoring and automated enforcement of security policies. This is much in alignment with federal priorities, wherein agencies need to ensure compliance with FedRAMP, FISMA, and NIST guidelines while remaining agile in cloud adoption (ATARC 2022). Moreover, the use of DevSecOps in cloud-native environments allows agencies to adopt a “shift-left” approach to security which integrates security checks into early development rather than leaving it to post-deployment audits. Working with cultural change, process adaptation, and automated tooling, cloud-native DevSecOps will improve resilience against human error and external threat, thereby creating a strategic linchpin for securing federal cloud infrastructures.

Federal Cybersecurity and Resilience Literature

Federal cybersecurity documents, assigned to a high degree to security asset as a measure of resilience rather than only by prevention. According to (NIST SP 800-160), (Volume 2), cyber resilience is the ability of a system to foresee, prevent, recover from, and adapt to adverse cyber events (Ross et al., 2021). This perspective underscores that threats are increasingly prevalent, and as their sophistication grows, recovery and adaptability become nearly as essential as preventive measures. For example, the internal strategies employed in the framework of federal information systems must ensure continuing and successful execution of mission-critical operations even in situations with protracted or new cyber threats. This resilience-oriented view applies well to the governance continuous delivery and cloud-native development models, whereby systems keep being updated and software deployed without going offline. Within such environments, traditional security checkpoints are often too slow or rigid, creating potential gaps that attackers can exploit.

DevSecOps solves these challenges by injecting automated security into development pipelines, which enable agencies to continuously monitor, detect, and remediate vulnerabilities nearly in real-time (Mohammed, 2025). Zero Trust, which demolishes the line of implicit trust, is thereby reinforced by SP 800-207 so that there becomes a continuing verification of all users, devices, and workloads (Rose et al., 2020). Scholars observe that implementing Zero Trust cannot rely on static controls alone; rather, they require full automation and continuous telemetry with dynamic enforcement of policies, all driven by DevSecOps pipelines. Infusing elements of resilience with principles of cloud-native DevSecOps practices may result in a case where federal agencies are well-placed to avail of continuous operational and adaptive processes while achieving speedy recovery from cyber incidents.

Oversight Reports and Incident Analyses

Agencies tasked with oversight and accountability, such as the U.S. Government Accountability Office (GAO), are instrumental in assessing the responses of federal systems to specific cyber threats. However, such reports following serious incidents as far-reaching as SolarWinds supply-chain attacks and vulnerabilities on Microsoft Exchange highlighted far-reaching gaps-such as delays in detecting threats, disparate monitoring in different agencies, and poor software supply-chain security (GAO 2022). These scenarios demonstrate that the inability to defend against cyberattacks arises not only from isolated technical failures but also from a convergence of systemic failures that shape how software is designed, developed, and operated.

The Cybersecurity and Infrastructure Security Agency (CISA) and Department of Defense (DoD) have thus issued guidance stressing proactive measures such as Software Bill of Materials (SBOMs), code-signing, and securing CI/CD pipelines (CISA, 2023; DoD, 2023). These steps are about more than regulatory compliance; rather, they are about resilience-building by incorporating security from the very beginning of the development process—in short, to catch problems early before they can cascade into a full-blown breach. As a matter of fact, the oversight reports and technical guidance together draw one clear conclusion: Security should be embedded in every layer of the software development lifecycle. Similarly, DevSecOps enables this injection of automated checks, continuous monitoring, and compliance validations directly into development and deployment pipelines. This goes beyond just fixing vulnerabilities—it builds systems that are adaptive, responsive, and resilient to ever-evolving cyber threats.

Identified Gaps

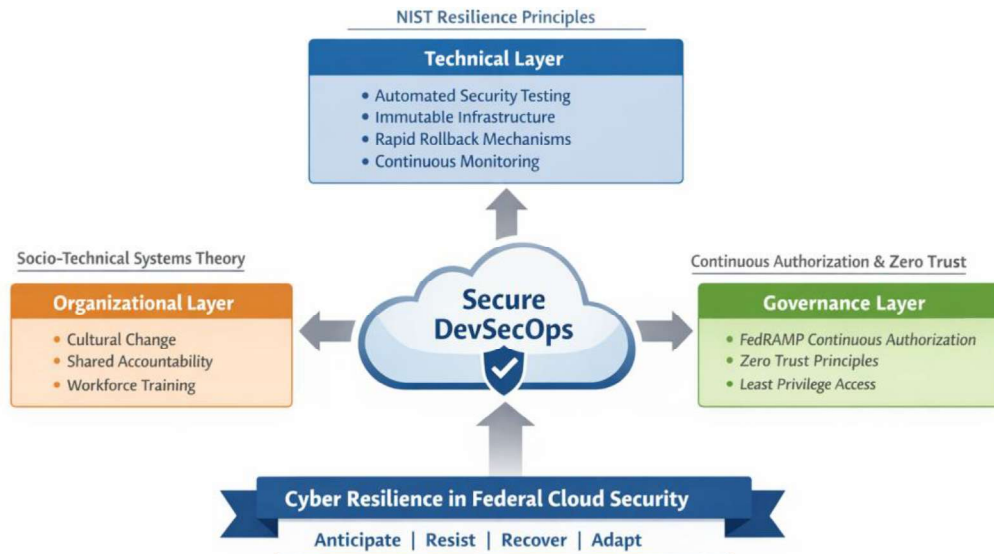
Despite the number of guidelines and best practices made available, research keeps proving that there are several challenges that remain in applying DevSecOps into the federal government. For instance, it is argued that agencies do not have the personnel skills sets necessary for integrating security seamlessly into development and operations. Practices vary in application, from agencies that are making good progress to those lagging due to either legacy systems or unavailability of resources. Besides, many of the governing structures are tied to static authorization models that simply do not fit the fluid and constantly changing nature of DevSecOps (Rajapakse, 2022; GAO, 2022). It is clear, this proves the need for collective theorizing and a structured scientific methodology to guide agencies into scaling DevSecOps effectively. The framework would go beyond the technical side to address organizational culture, workforce development, and policy alignment in a manner that helps make federal systems more secure, resilient, and adaptable to evolving cyber threats.

The discussion of existing gaps reveals that there are technical and organizational barriers that federal DevSecOps adoption entails. Many of these technical challenges involve integrating automated security tools into existing cloud and legacy systems, a task not made easy by the large number of different platforms and software stacks with which agencies must cope. There are also organizational challenges, for example, cultural resistance, fragmented processes and limited collaboration across other agencies, which might delay the implementation as well. At the same time, these hurdles can present opportunities: by harmonizing best practices, investing in workforce training, and aligning governance models with continuous security principles, agencies can not only bridge existing gaps but also hasten building resilient and cloud-native systems. Understanding of these challenges and opportunities will help design well-thought-out strategies that take DevSecOps from being practical to becoming one of the sustainable technologies of choice at scale in the federal government.

Theoretical Framework

This study adopts the socio-technical cyber resilience framework in assessing secure DevSecOps adoption within a federal environment, drawing on theories from systems engineering, organizational change, and governance. The framework asserts the connections among technical practice, human factors, and policy structure that play into the overall effectiveness of DevSecOps to improve federal cyber resilience.

Figure1: Socio-Technical Cyber Resilience Framework for Secure DevSecOps in Federal Cloud Environments



At the *Technical layer*, the framework leans on NIST's cyber resilience concepts, emphasizing four key capabilities: anticipation, resistance, recovery, and adaptation (Ross et al., 2021). Secure DevSecOps practices translate these into concrete measures, such as automated security testing to expose vulnerabilities to early or immutable infrastructure to thwart configuration drift, rapid rollback mechanisms for post-incident recovery, and continuing monitoring for situational awareness and responsiveness.

At the *organization Layer*, this framework uses the socio-technical systems theory, which argues that the effective application of technology is all about how well it is matched to human, cultural, and governance structures. The organizational culture transition allows the employees to shift their focus from being held accountable for siloed responsibilities to being shared in their own accountability reinforced by leadership commitment, clear incentive structures, and a future employees' training program on a successful transition to DevSecOps (Rajapakse, 2022). The technical solutions are not implemented in isolation but are fully integrated with the people, processes, and decision-making dynamics in the organization.

At *The governance layer*, the framework includes federal policy mechanisms, which include continuous authorization by FedRAMP and the Zero Trust principles. Continuous authorization is the transformation of the stationary traditional security controls into dynamic processes that are living and breathing, whereas Zero Trust conveys to establish least-privilege access and assume continuous verification across the users, devices, and workloads. These measures of governance steer DevSecOps pipelines to operate securely under regulatory and compliance frameworks. The result of these layers will be a holistic framework that presents secure DevSecOps as the operational linkage between cyber resilience theory and practical use in federal cloud security. It provides a lens through which to see how technical, organizational, and governance factors come together to create systems that can be resilient, adaptive, and secure at the federal level.

Methodology

With secondary data as the mainstay, this study employs structured designs for operationalizing qualitative synthesis. The research design sets up a systematic pathway for the identification, selection, and analysis of pertinent secondary sources, thereby affording rigorous, traceable outcomes. The study maps federal cybersecurity guidance, oversight reports, and peer-reviewed studies directly to qualitative research questions, generating methodological transparency considering restricted access to primary operational data. Structured design promotes reproducibility, allowing other researchers to apply the same coding and thematic analysis approaches; this ensures that the next sections—data sources, analysis procedures and interpretation—are anchored in a clearly designed framework for the assessment of secure DevSecOps adoption and federal cyber resilience.

Research Design

The research design is one that indeed adopts an approach that uses qualitative secondary-data synthesis—implies for studying federal cybersecurity practice on direct access to operational data not available, secure, or classified. It indeed allows hounds compilation of systematic authors for building comparisons and interpretation around insights into secure DevSecOps adoption and cyber resilience strategies from existing authoritative sources. Thus, access to secondary data means using publicly available information while maintaining the rigor of good source selection and analysis. Research design is iterative and reflective, in that it allows the patterns that emerge to steer deeper investigations into different types of sources. It does not seek to quantify outcomes in operational terms, but instead stresses developing a thematic understanding of federal cybersecurity practices. In such insights, policy, and practice inform each other: both formal instruction by standards and observed trends and perceive challenges in results.

Data Sources

For this study, there existed four main primary types of secondary sources, deemed appropriate to create a sound and balanced understanding of federal cybersecurity practice as follows.

1. Federal Standards and Frameworks - NIST SP 800-160 and SP 800-207 are some of the documents that were reviewed by this research. These are the frameworks that set forth expectations of the federal government in the implementation of secure system development, zero trust architecture, and overall cyber resilience.

2. Federal Programs and Guidance - This included operational guidance, such as the FedRAMP Rev5 Continuous Monitoring Playbook, CISA cloud and supply-chain guidance, and recommendations on software bills of materials (SBOM) from DoD. The guidance provides concrete instances of implementation strategies and practical controls adopted by federal agencies on implementation.

3. Oversight and Accountability Reports - This information is drawn from GAO reports on federal cyber incidents, workforce readiness, and evaluations in different programs to identify in them gaps, risk patterns, and lessons learned after real-world implementations at the federal level.

4. Peer-Reviewed Literature - This provided a synthesis of recent systematic reviews and empirical studies on emerging topics of DevSecOps, cloud security, and organizational resilience conducted between 2019 and 2025, which enhanced the federal documents with evidence-based lenses on emerging practices and

challenges. In line with the inclusion and exclusion criteria, selected sources were assessed in terms of authority, relevance to the federal cloud systems, and methodological rigor. Inclusion criteria represented the credibility of authority, timeliness in publication, and research alignment, while exclusion criteria included obsolete or non-reproducible ones.

Data Analysis Procedure

An inductively determined thematic coding of the documents examined enabled the identification of topics, patterns, and principles relative to the database analyzed. The principal themes listed below were:

• **Automation** – Automated pipelines and continuous testing in DevSecOps workflows with security by design.

- **Pipeline Security** – Security of code integration, build, and deployment pipelines.
 - **Continuous Authorization** – Continuous checks for compliance to keep the system authorized.
 - **Supply-Chain Controls** – Assessments of dependency, vendor risk, and SBOM practices.
 - **Workforce Readiness** – Skills, training, and organizational support necessary for secure DevSecOps.
 - **Resilience Outcomes** – Metrics and practices pertinent to anticipation, resistance, recovery, and adaptation.
- Cross-comparisons of themes among source categories were conducted to ascertain instances of convergences and divergences among policy, oversight findings, and academic literature. Triangulation thus acted to enhance the internal validity and reliability of our conclusions, further reinforced in the knowledge that insights are anchored in multiple, independent streams of evidence. Our attention was thus directed toward patterns of convergence rather than single recommendations to showcase established practices while accommodating differences across agencies and contexts.

Methodological Limitations

Secondary data analysis gives excellent insights but has limitations which need to be considered:

1. Limited Direct Operational Measurement: Operations of the system cannot be directly measured using this technique. For example, it does not measure live operational outcomes like mean time to recover (MTTR) or vulnerability exploitation rates in real time. This measure restricts quantification of certain aspects of a system's resilience.

2 Underreporting of Sensitive Information: Operative weaknesses, incidents in progress, or agency-specific security failures-related public documents may otherwise remain undisclosed, due to classification or reputational concerns.

3. Temporal and Contextual Limitation: The collected datasets inform guidance, reporting, and studying only between 2019-2025, which may be insufficient to capture the quickly developing threats or emerging technologies in their totality. It is important to note that this study is likely to minimize these weaknesses through reliance on GAO oversight reports, authoritative frameworks, or peer-reviewed studies, all of which account for independent verification and aggregate evidence. Triangulation across sources establishes confidence in those findings while providing an enriched understanding of the state of federal DevSecOps practice and of trends in cyber resilience.

Findings and Discussion

This chapter depicts the findings and analyses resulting from a qualitative synthesis of federal guidance, oversight reports, and peer-reviewed literature. Rather than placing a discussion of results in isolation, this chapter considers the technical, organizational, and governance aspects of DevSecOps and how a set of practices contribute to cyber resilience in federal cloud environments.

These findings indicate that resilience does not emerge from specific isolated security measures; rather, it is developed within a network of DevSecOps-type mechanisms defined to automate the enforcement of such controls and continuously end-to-end visibility into risk assessment, combined with adaptive learning. Such mechanisms provide intervention capabilities towards the entire system lifecycle, including design, development, deployment, operation, and recovery. Therefore, these mechanisms can operationalize the resilience capabilities of anticipation, resistance, recovery, and adaptation given in the theoretical framework. The following section synthesizes the general mechanics of DevSecOps that consistently associate with better resilience outcomes across secondary sources and then maps them to specific resilience capabilities before evaluating the organizational barriers that hinder their adoption.

Additionally, the findings state that resilience outcomes such as reduced blast radius, faster time to recovery, and continuous adaptation will be achieved most effectively using DevSecOps when it is operated as a supported and continuously governed operation rather than as just a collection of tools or through automation practices (NIST, 2021; FedRAMP PMO, 2023). This justifies the socio-technical framing of the study while also showing that a combination of technical automation and institutional governance is needed for possible sustainable resilience in the federal cloud environments. Most importantly, the findings point out that resilience outcomes. For example, reduced blast radius, faster time to course recovery, and continuous adaptation--can be realized through DevSecOps when that feature becomes an authorized, continuously governance-supported operational model rather than a collection of tools or automation practices (NIST, 2021; FedRAMP PMO, 2023). This argues for socio-technical framing of the study and underscores the need to combine technical automation with institutional governance for possible sustainable resilience in federal cloud environments.

Table 1. Mapping DevSecOps Mechanics to Cyber Resilience Capabilities

<i>DevSecOps Mechanic</i>	<i>Anticipate</i>	<i>Withstand (Resist)</i>	<i>Recover</i>	<i>Adapt</i>
<i>Infrastructure as Code (IaC) & Policy-as-Code</i>	<i>Enables pre-deployment validation of configurations and security baselines</i>	<i>Enforces immutable, standardized environments that limit attack propagation</i>	<i>Supports rapid rollback and system reconstitution from trusted artifacts</i>	<i>Lessons learned can be encoded into updated infrastructure and policy templates</i>
<i>Automated CI/CD Security Gates (SAST, DAST, SCA, secrets detection)</i>	<i>Identifies vulnerabilities and risky dependencies early in the development lifecycle</i>	<i>Prevents insecure code from reaching production environments</i>	<i>Reduces remediation scope by catching issues before deployment</i>	<i>Pipeline rules and controls evolve based on incident outcomes and metrics</i>

<i>Software Supply-Chain Controls (SBOMs, code signing, vendor attestation)</i>	<i>Improves visibility into third-party components and emerging dependency risks</i>	<i>Verifies software integrity and reduces exposure to compromised components</i>	<i>Accelerates incident triage and targeted remediation</i>	<i>Inform procurement, dependency selection, and supplier risk management changes</i>
Continuous Monitoring & Evidence Automation (FedRAMP ConMon)	<i>Enables early detection of anomalies and control degradation</i>	<i>Supports timely corrective actions to maintain authorization posture</i>	<i>Provides real-time evidence to guide recovery actions</i>	<i>Empirical telemetry informs control refinement and governance improvements</i>
Blameless Postmortems & Feedback Loops	<i>Identifies systemic risks and weak signals before future incidents</i>	<i>Strengthens institutional awareness and preparedness</i>	<i>Improves response coordination and documentation</i>	<i>Institutionalizes learning and continuous improvement across teams</i>

Explanation and interpretation of Table

This table synthesizes insights from federal guidance (NIST, FedRAMP), oversight reports (GAO), and peer reviews literature to illustrate how core DevSecOps mechanics contribute to the four resilience capabilities: anticipate, withstand (resist), recover and adjust. Operational metrics mean time to recover or those related to an incident were not directly available; instead, the mapping reflects patterns, principles, and recommendations that have been consistently identified across a wide range of authoritative secondary sources. The table is meant to provide a structured conceptual framework linking documented DevSecOps practices to resilience outcomes in federal cloud environments.

Implications for Federal Cyber Resilience Strategy

In the broad context of the federal cyber resilience strategy, this chapter will position the findings of the study and put an emphasis on how secure DevSecOps translate resilience from theory to operationalization.

DevSecOps as an Operationalization of Resilience Theory

Resilience in NIST's cyber resilience framework is defined as the ability to anticipate, withstand, recover from, and adapt to cyber adversities (Ross et al., 2021). These constructions are theoretically sound, but federal agencies have not been able to convert these into operations. Evidence from this study, which basic secondary evidence converges on, shows that secure DevSecOps can practically operationalize resilience theory into federal cloud and information systems.

Peer-reviewed research has increasingly proven that the integration of automated security controls within the CI/CD pipeline promotes the capability of anticipation because it detects vulnerabilities, poor configuration, and risky dependencies before deployment (Rajapakse, 2022). This pre-emptive wildfire management means moving the risk upstream so that members of the local authority can respond to weaknesses before they cause operational incident outcomes. Assumption by federal guidelines emphasizes an extension of that finding,

where IaC and immutable deployment patterns enable the limitation of the infiltration's direct impact as well because they allow a speedy recovery through rollback and reconstruction (NIST, 2021).

In addition, continuous monitoring and authorization models-such as the ones promoted in (FedRamp Rev). Automatically support resilience in the adaptive dimension because they establish feedback loops and data-driven improvement processes. Automated evidence collection and real-time telemetry will continuously review risk and modify security controls and policies in response to changing threats-and that is the meaning of 'adaptive' security policy (FedRAMP PMO, 2023).

Policy and Governance Alignment

The findings support technical resilience could not be maintained without co-evolving policies and governance frameworks. Secondary federal sources, especially GAO oversight reports, continually reiterate misalignment within traditional, static modes of authorization and realistic mode deployments in delivery and cloud-native development (GAO, 2022). Compliance with documents in the form of periodic reviews of authorization becomes more at odds with pipelines that may deploy changes at high velocity. The transition of FedRAMP to continuous monitoring and ongoing authorization reflects an institutional recognition of this disjunction and is a critical policy pathway for extending secure DevSecOps to the federal agency. Because it allows for compliance evidence to be generated almost in real-time by automation, reporting for FedRAMP reduces the need for manual review while allowing for accountability and transparency, thus producing an environment of risk visibility.

This governance shift has been received in peer-reviewed literature, which states that policies must provide frameworks whereby automation can replace manual oversight without reducing control or transparency such that the effectiveness of DevSecOps may be realized (Mohammed, 2025). This includes reforms in procurement practices to support modular, continuously updated software; authorization processes that recognize dynamic risk postures; and performance measurement systems that emphasize resilience outcomes rather than checklist compliance. Taken together, these practices demonstrate secure DevSecOps as the translation layer between resilience theory and operational reality, bringing abstract resilience principles into life as measurable, repeatable, and auditable security practices within federal environments

Contributions to Research and Practice

In this section, the contributions of the study are expressed considering theoretical advances and practical implications. Given that the study revolves around socio-technical theory and federal cybersecurity operations, the contributions are grouped into two complementary categories: academic contributions and federal contributions. By this means, it is clear how the findings inform scholars and, in practical terms, real-world policy, governance, and operational decision-making in U.S. federal cloud environments.

Contributions to Academic Research

This contribution is added in terms of peer-reviewed DevSecOps research and the more federal cyber resilience frameworks, which are all under-examined in the current literature as far as this study is concerned. Much of the existing DevSecOps has been done in pure commercial and technical environments; however, for this study, DevSecOps has been established within the regulatory, operational, and national-security constraints unique to U.S. federal systems and has thus provided subtle insight into the interaction between governance, policy, and oversight mechanisms on secure software delivery practices. The result of this is

theoretical broadening in the frontiers of DevSecOps research, extending empirical realities beyond private-sector contexts and demonstrating the usefulness of socio-technical resilience frameworks in such high-assurance, regulated environments.

In addition to above, it is also a methodological contribution - secondary-data synthesis approach of this study demonstrates how theory-informed insights can be built even without having access to sensitive operational datasets by combining authoritative policy documents, oversight reports, and peer-reviewed literature. Gaps in literature, especially where access is limited, have often hampered empirical research in public-sector IT, and this addresses that gap. Finally, it is in alignment with calls for more DevSecOps research focusing on public sectors to capture the real-world constraints of governance, legal compliance, and risk management obligations within public sectors (Rajapakse, 2022; Mohammed, 2025). As such, the study counsels a conceptual and methodological roadmap on future research directed towards bringing close academic theory to federal practice.

Contributions to Federal Practice

For practitioners, the relevant findings will make way for how best to adopt secure DevSecOps in very complicated federal environments. This takes note of keynote arguments as to how agencies should ensure that:

Automation controls validation in human ways - that security checks are piped into pipelines instead of requiring a human to reduce the possibility for human error and accelerate cycle times.

supply-chain assurance over perimeter defenses-chain assurance instead of perimeter defenses - make visible and integrity from third-party components through SBOMs, code signing, and vendor attestation.

Continuous authorization over episodic compliance- measures more thorough than point-in-time assessments will be ongoing monitoring and real-time risk posture evaluations.

Continuous authorization over episodic compliance-Security shared between all development, operations, and governance teams.

These recommendations are based on strong secondary evidence ranging from federal guidance (NIST, FedRAMP), oversight reports (GAO), and systematic reviews of literature on DevSecOps. The latter two will highlight the interrelations between technical automation and governance aligning with organizational culture, suggesting that secure DevSecOps will best be implemented as a continuously managed, policy-aligned operational model rather than disparate tooling. In fact, such an approach improves agency resilience and lowers operational risk, while even making practice meet both regulatory expectation and best practice evidence (NIST, 2021; CISA, 2023; GAO, 2022).

Policy and Technical Recommendations for Federal Secure DevSecOps Adoption

Drawing on a synthesis of federal standards, operational guidance, oversight reports, and peer-reviewed literature, the study offers a package of integrated policy and technical recommendations which would spur secure DevSecOps adoption across U.S. federal cloud and information systems. These recommendations are based on a socio-technical resilience perspective: sustainable cyber resilience grows from enabling

automation, governance, workforce capability, and organizational culture to work in concert rather than by isolated technical controls (Ross et al., 2021; Rajapakse, 2022).

Figure 2: Socio-Technical Recommendations for Strengthening Cyber Resilience through Secure DevSecOps in Federal System



- **Institutionalize Automation as a Security Baseline**

As the federal agencies move forward, the implementation of automation technology—including both Infrastructure as Code (IAC) and policy-as-code (PaC)—should become incorporated as a baseline model and should not be considered as an option worth having but rather a requirement for carrying out secure cloud operations. NIST guidance indicates that the ability to reproduce system configurations in an automated manner is meant to reduce the risks of misconfiguration that also improves system integrity through the entire lifecycle (NIST SP 800-160 Vol. 2, 2021). Therefore, by instilling automated security testing mechanisms, including static and dynamic analysis, software composition analysis, and secrets detection, directly into the CI/CD pipelines, it will help in early identification of vulnerabilities and reduces the cost of remediation (Rajapakse, 2022; Mohammed, 2025). Such type of automation will be resilient enough to be able to forecast and resist cyber threats before deployment.

- **Transition from Episodic Authorization to Continuous Authorization**

The traditional Point-in-Time authorization models seem to be out of sync with cloud-native systems that arrive with changes in frequency and with automation. Federal agencies should accelerate the transition toward continuous authorization, as promoted by (FedRAMP Rev. 5), by integrating automated evidence generation and real-time telemetry into DevSecOps pipelines (FedRAMP PMO, 2023). Continuous monitoring should serve not only compliance objectives but also operational risk management, allowing agencies to maintain authorization while dynamically adapting to evolving threats (NIST SP 800-37 Rev. 2, 2022). This shift directly addresses GAO-identified weaknesses related to delayed detection and fragmented oversight in federal systems (GAO, 2022).

- **Strengthen Software Supply-Chain Security through DevSecOps Integration**

The Software supply-chain compromises are clear indicators of fundamental national security, thus having severely weakened the federal functions and services of the entire United States. Oversight reports following the SolarWinds incident highlight deficiencies in dependency visibility, vendor risk management, and integrity

verification mechanisms (GAO, 2022). Federal agencies should embed supply-chain security controls, including Software Bills of Materials (SBOMs), code signing, and dependency provenance validation directly into DevSecOps workflows (CISA, 2023; DoD, 2023). Integrating these controls into CI/CD pipelines improves visibility into third-party components, supports faster incident triage, and strengthens resilience by limiting blast radius and accelerating recovery.

- **Aligning Governance and Procurement Policies with Continuous Delivery Models**

A well-governed and procured DevSecOps practice is one that enables automation and agility sans accountability compromises. (GAO, 2022) reports continued to show that misalignment between static authorization processes and modern continuous delivery practices does indeed hinder federal cloud security. Policy makers should modernize procurement and authorization policies to recognize automated compliance evidence as authoritative, support incremental authorizations, and more emphasize resilience outcomes over checklist-based compliance (FedRAMP PMO, 2023; NIST, 2021). Aligning governance with DevSecOps allows agencies to operationalize Zero Trust principles and maintain secure cloud operations at scale (NIST SP 800-207, 2020; OMB, 2022).

- **Invest in Workforce Development and Cross-Functional Skills**

Lack of workforce readiness continues to jeopardize the federal sector's efforts for safe DevSecOps. Shortage of cloud security skills and cross-functional DevSecOps capabilities emerge within the GAO oversight reports as risk factors (GAO, 2023). Agencies would need to invest in targeted initiatives for workforce development that would seek to emphasize secure cloud engineering, automation, and more continuity in risk management. Such initiatives should go hand in hand with a revision of the role definitions and incentive structures that produce a mutually beneficial reward system for collaborative roles and shared accountability of release, security, and operations (Rajapakse, 2022; Mohammed, 2025).

- **Foster Organizational Culture that Supports Shared Security Responsibility**

Beyond the technical and policy reforms, organizational culture is decisive in determining the effectiveness of DevSecOps. According to socio-technical systems, technology adoption is always successful when converged to human behaviors, leadership commitment, and institutional norms (Ross et al., 2021). By developing a shared culture of security responsibility, non-blame post-incident analysis, and continuous learning, federal agencies would gain by leveraging a cultural co-alignment that allows their individual DevSecOps to serve as an adaptive resilience mechanism and not just a collection of tools towards much more sustained advancements in anticipation, recovery, and adaptation to cyber threats (Rajapakse, 2022).

This policy and technical recommendation position secure DevSecOps as an operating-level bridge from federal cyber resilience theory to cloud implementation in practice. In establishing automation as an institution, with continuous authorization, embracing supply-chain security, extending governance into continuous delivery, investing in workforce development and supportive organizational cultures, federal agencies will then be truly ready to make the shift from compliance-focused security to adaptive and resilient cloud operations that can survive changing cyber threats (NIST, 2021; FedRAMP PMO, 2023; GAO, 2022).

Limitations and Directions for Future Research

Before outlining specific limitations, it is important to contextualize the scope and methodological approach of this study, highlighting how reliance on secondary data shapes both the insights gained and the boundaries of generalizability

Limitations of Secondary-Data Research

This research, being in secondary data, did not include any primary empirical measures such as real-time incident response times, mean time to recovery, or vulnerability exploitation rates. More specific evaluations of the application of DevSecOps would benefit from such metrics, but access to the data is constrained by national security, privacy, and classification requirements. Consequently, the study relies on publicly available federal guidance, oversight reports, and peer-reviewed literature, which may underrepresent sensitive operational deficiencies or agency-specific implementation challenges. For example, reports from the Government Accountability Office (GAO) and FedRAMP point out systemic trends but usually shy away from disclosing internal telemetry that would definitively establish control effectiveness.

The limitations are mitigated through triangulation against independent oversight reports and systematic reviews, which furnish validated, aggregated insight as opposed to anecdotal or self-reported information. Instead of measuring sensitive operational outcomes, the study examines broadly applicable patterns, practices, and principles of governance across federal cloud environments. Inclusion of the analysis in the context of socio-technical resilience serves to strengthen the integration of technical controls with governance, workforce, and policy inputs, giving further weight to the conclusions reached in view of the data constraints.

On the other hand, secondary synthesis may not capture all the dynamic realities involved in federal cloud operations. Rapidly changing technologies, emerging threat vectors, and contexts that are specific to an agency's workflow may not be adequately described in current documentation published. Therefore, findings should be viewed as evidence-informed guidance, not as substitutes for live testing of system operations. These limitations serve to reinforce the intrinsic trade-offs associated with research based on secondary data: broadly based, ethical, and legally compliant at the price of specific operational metrics. Future work should build on this research with primary data collection, longitudinal studies, and cross-agency empirical analyses to further validate and extend the resilience-oriented DevSecOps insights provided herein.

Directions for Future Research

As future research goes along, it will meaningfully deepen the comprehension of secure DevSecOps in federal ecosystems by addressing the limitations due to secondary-data analyses.

First, case studies on agency-level implementations of DevSecOps would have delivered a very detailed view of how practices are operationalized in organizational contexts. Such inquiry could benefit from illuminating how this translates into a network of relations among technical automation and governance structures, capabilities in the workforce, and organizational culture, thus clarifying the socio-technical mechanisms that run cyber resilience.

Second, a quantitative correlation analysis between the maturity of DevSecOps and certain quantifiable resilience outputs mean time to recovery, patch latency, the frequency of incident occurrences, and the downtime of systems opens a more empirical base for validating the theoretical relationships stipulated by the

current study. As far as feasible, access to anonymized operational data would collect scientifically rigorous evidence for and identification of statistically supported best practices.

Thirdly, one may consider cross-comparison between civilian and defense agencies, exploring whether differences in governance models, regulatory constraints, and threat environments impact DevSecOps adoption and DevSecOps effectiveness. This line of analysis will then inform more tailored policy recommendations while identifying transferable lessons across federal contexts. Lastly, evaluating new technologies, especially AI-powered DevSecOps tools, is an area ripe for future exploration. With increased adoption of artificial intelligence and machine learning by federal agencies for spotting vulnerabilities, ensuring automated compliance, and assessing predictive risks, there will be a growing need for systematic research into their value-for-money resilience enhancement opportunities and corresponding governance challenges. Collectively, therefore, these lines of inquiry will create brighter vision, actionable direction in less misleading secondary-data synthesis. Furthering these tracks of inquiry will add to the global understanding on academic's proof yet actual implementation of secure DevSecOps towards more resilient federal cloud and information systems.

Conclusion

The thorough synthesis of secondary federal data and peer-reviewed research results in concluding that building strong models of secure DevSecOps is strategic craving within the national security measures to strengthening cyber resilience among the cloud and federal information systems of the U.S. government. Evidence, standards, and oversight show a synchronous point of convergence: effective resilience within the modern federal environment is not the one achieved through tools alone but rather through practices with automated and continuous application, policy alignment, and deep insertion into the organizational culture. The concept of Secure DevSecOps is a socio-technical mechanism that translates the theory of resilience into practical application. Thus, automating technology and governance, human capability, and iterative feedback enable federal agencies to transition from a reactive, event-based defense toward adaptive, proactive resilience. This approach ensures that essential government systems are trustworthy, available, and mission-capable in the face of increasingly sophisticated, persistent, and rapidly evolving cyber threats. Ultimately, this study will prove that the adoption of secure DevSecOps goes beyond the technical or operational improvement but rather serves as a fundamental basis for federal cyber resilience by bridging the gap between theoretical constructs that remain abstract and action-oriented and long-lasting security practices. The implications can provide researchers and practitioners alike with a clear path on how to become better prepared at securing, optimizing operational efficiency, and ensuring federal information systems' ability to stand up against, recover from, and adapt to cyber challenges that lie ahead.

Declaration of Conflicting Interests

The authors declare no potential conflicts of interest with respect to the research, authorship and publication of this article.

Funding

The author received no financial support for the research, authorship and publication of this article.

References

- CISA. (2023). Secure software development practices.
- Cybersecurity and Infrastructure Security Agency (CISA). (2023). Cloud security technical reference architecture (Version 1.1). U.S. Department of Homeland Security. <https://www.cisa.gov/cloud-security>
- Cybersecurity and Infrastructure Security Agency (CISA). (2023). Secure software development practices. <https://www.cisa.gov/secure-software-development>
- Department of Defense (DoD). (2023). Recommendations for software bill of materials (SBOM) management. <https://www.dodcio.defense.gov>
- FedRAMP Program Management Office. (2023). FedRAMP continuous monitoring (ConMon) playbook (Rev. 5). <https://www.fedramp.gov>
- FedRAMP Program Management Office. (2023). FedRAMP continuous monitoring (ConMon) playbook (Rev. 5).
- FedRAMP Program Management Office. (2024). FedRAMP authorization and continuous authorization guidance. <https://www.fedramp.gov>
- General Services Administration (GSA). (2023). DevSecOps guide for federal agencies. <https://www.gsa.gov>
- Government Accountability Office (GAO). (2022). Federal response to SolarWinds and Microsoft Exchange cyber incidents (GAO-22-104746). <https://www.gao.gov/products/gao-22-104746>
- Government Accountability Office (GAO). (2022). Federal response to SolarWinds and Microsoft Exchange cyber incidents (GAO-22-104746).
- Government Accountability Office (GAO). (2023). Cybersecurity: Federal agencies need to address workforce challenges. <https://www.gao.gov>
- Government Accountability Office (GAO). (2023). Cybersecurity: Federal agencies need to address workforce challenges.
- Mohammed, K. I. (2025). Evolution of DevSecOps and its influence on application security: A systematic literature review. *Technologies*, 13(12), 548. <https://doi.org/10.3390/technologies1312054>
- Mohammed, K. I. (2025). Evolution of DevSecOps and its influence on application security.
- NIST. (2020). Zero trust architecture (NIST SP 800-207). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-207>
- NIST. (2020). Zero trust architecture (SP 800-207).
- NIST. (2021). Developing cyber-resilient systems (SP 800-160 Vol. 2).
- NIST. (2021). Developing cyber-resilient systems: A systems security engineering approach (NIST SP 800-160 Vol. 2)

- Rev. 1). <https://doi.org/10.6028/NIST.SP.800-160v2r1>
- NIST. (2022). Risk management framework (SP 800-37 Rev. 2). <https://doi.org/10.6028/NIST.SP.800-37r2>
- NIST. (2022). Risk management framework for information systems and organizations (NIST SP 800-37 Rev. 2). <https://doi.org/10.6028/NIST.SP.800-37r2>
- NIST. (2023). Secure software development framework (SSDF) (NIST SP 800-218). <https://doi.org/10.6028/NIST.SP.800-218>
- Office of Management and Budget (OMB). (2022). Moving the U.S. government toward zero trust cybersecurity principles (M-22-09). <https://www.whitehouse.gov/omb>
- Rajapakse, R. N. (2022). Challenges and solutions when adopting DevSecOps: A systematic literature review. *Information and Software Technology*, 143, 106760. <https://doi.org/10.1016/j.infsof.2021.106760>
- Rajapakse, R. N. (2022). Challenges and solutions when adopting DevSecOps.
- Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero trust architecture (NIST SP 800-207). NIST.
- Ross, R., et al. (2021). Developing cyber-resilient systems.
- Ross, R., et al. (2021). Developing cyber-resilient systems: Systems security engineering considerations. *IEEE Security & Privacy*, 19(3), 80–87. <https://doi.org/10.1109/MSEC.2021.3054222>
- Sinan, A. (2025). DevSecOps frameworks for cloud-native environments: A systematic review. *Journal of Cloud Computing*, 14(1), 22. <https://doi.org/10.1186/s13677-025-00432-9>
- Stine, K., Quinn, S., Witte, G., & Gardner, R. (2022). Application container security guide (NIST SP 800-190). NIST.
- U.S. Department of Homeland Security. (2023). National cybersecurity strategy implementation plan. <https://www.dhs.gov>
- U.S. Government Accountability Office (GAO). (2021). Cybersecurity supply chain risk management. <https://www.gao.gov>
- Vasconcelos, A., Rocha, Á., & Andrade, R. (2021). Improving software security through DevSecOps: A conceptual framework. *Computers & Security*, 109, 102386. <https://doi.org/10.1016/j.cose.2021.102386>
- Wiedemann, A., Forsgren, N., & Humble, J. (2021). Accelerate and secure: DevSecOps performance outcomes. *ACM Queue*, 19(5), 34–49. <https://doi.org/10.1145/3488659>